

Module 1: Web Application Security

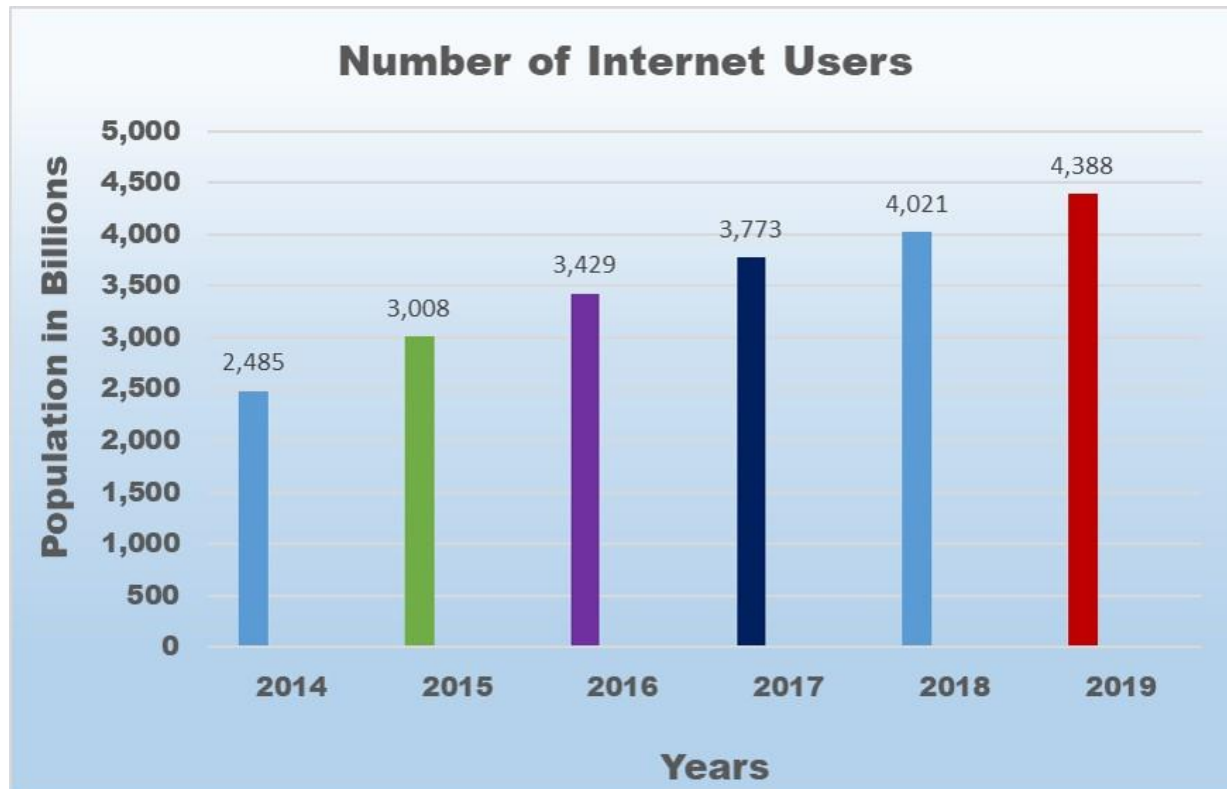
Unit 1: Security Landscape

Objectives

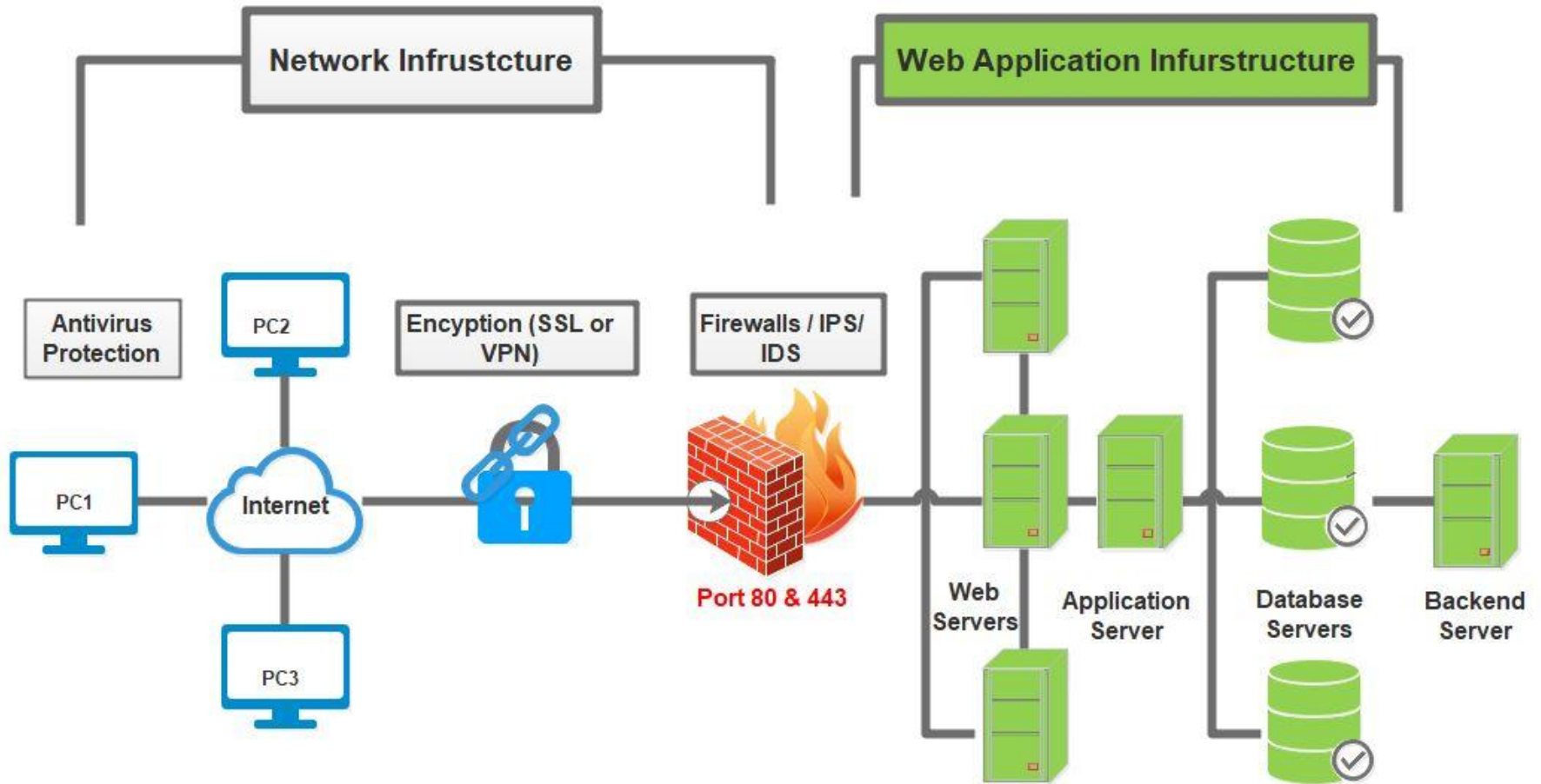
At the end of this lesson, students will:

- Have an understanding of Internet usage
- Describe the web application security problems
- Identify organizations that are trying to help
- Have an understanding of security testing techniques
- Enumerate challenges facing security testers

Internet Usage Stats



Understanding the Problem



Web Application Misconception

“we perform Network Vulnerability Assessments”

- looks for vulnerabilities at the network layer.
- neglects security software issues on servers. E.g
 - ✓ Application Servers
 - ✓ Database Servers
 - ✓ Backend servers

Web Application Misconception(conti)

“we have firewalls, IDS/IPS in place”

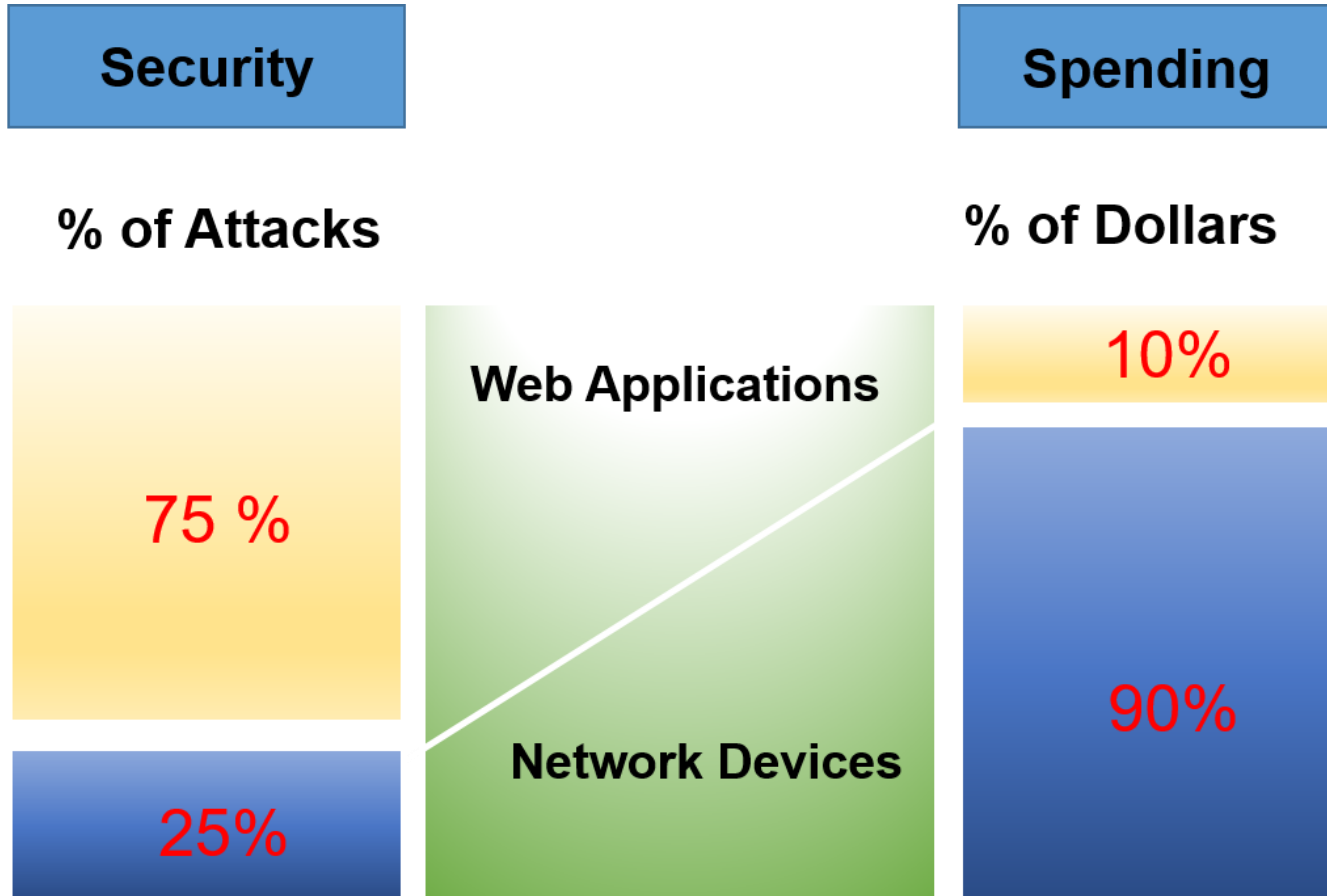
- Some ports on those firewalls are open for use
 - ✓ Such as port 80 for web traffic
 - ✓ And port 443 for domain name services
- And could be exploited

Web Application Misconception(conti)

“we have encryption algorithms”

- SSL and VPNs only encrypts data in transit.
 - ✓ The data need to be decrypted before it can be used by the application
 - ✓ This only protects the data between the user and the site but not the application
- These algorithms are great at the network layer

Unbalanced Budget Allocation



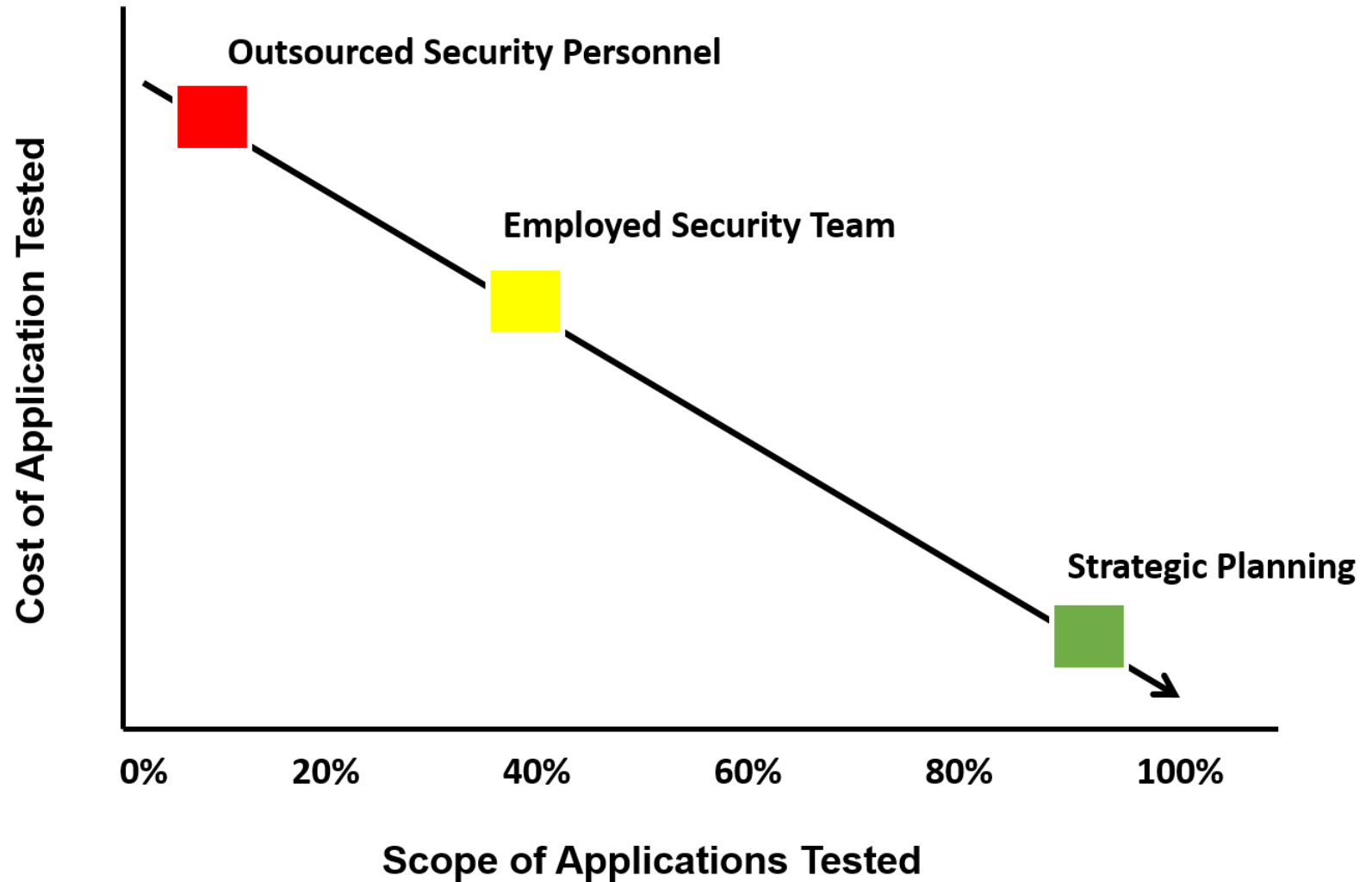
The Impact of Unsecure Web App

- Application shutdown
 - ✓ major loses (customers)
 - ✓ damage to the brand
- Identity Theft
 - ✓ steal sensitive customer data
 - ✓ bank accounts
- Modify the application look
 - ✓ mislead customers
- Hackers could execute remote commands

The Impact of App Security Breach

- Customer loss
- Grab media attention
- Face customer lawsuits
- Force for security auditing
- Allocate Budget for new security spending

Possible Solution



Organizations are Trying to Help

- OWASP
- WASC
- Netsparker
- veracode
- immuniWeb

The Open Web App Security Project

- Established in December 2001, United States
- Open source community
- Freely produces and maintain a list of top ten web app vulnerabilities.
- Since 2004, a new list of top ten is released
- This happens after every three years
- This course will discuss the 2023 top ten list

Web Application Security Consortium

- Is a non-profit organization that:
 - ✓ Develops
 - ✓ Adopts
 - ✓ And advocate standards for web applications
- Promote industry-standard terminologies and best practices

Security Testing Techniques

Scan Parameters	Black Box Testing	White Box Testing
Scan Input	Online Web Application	Supply Source Code
Assessment Method	Sends HTTP Messages	Looks for Patterns in Source Code
Scan Output	HTTP Response Messages	Line of Code is displayed

Black Box Testing



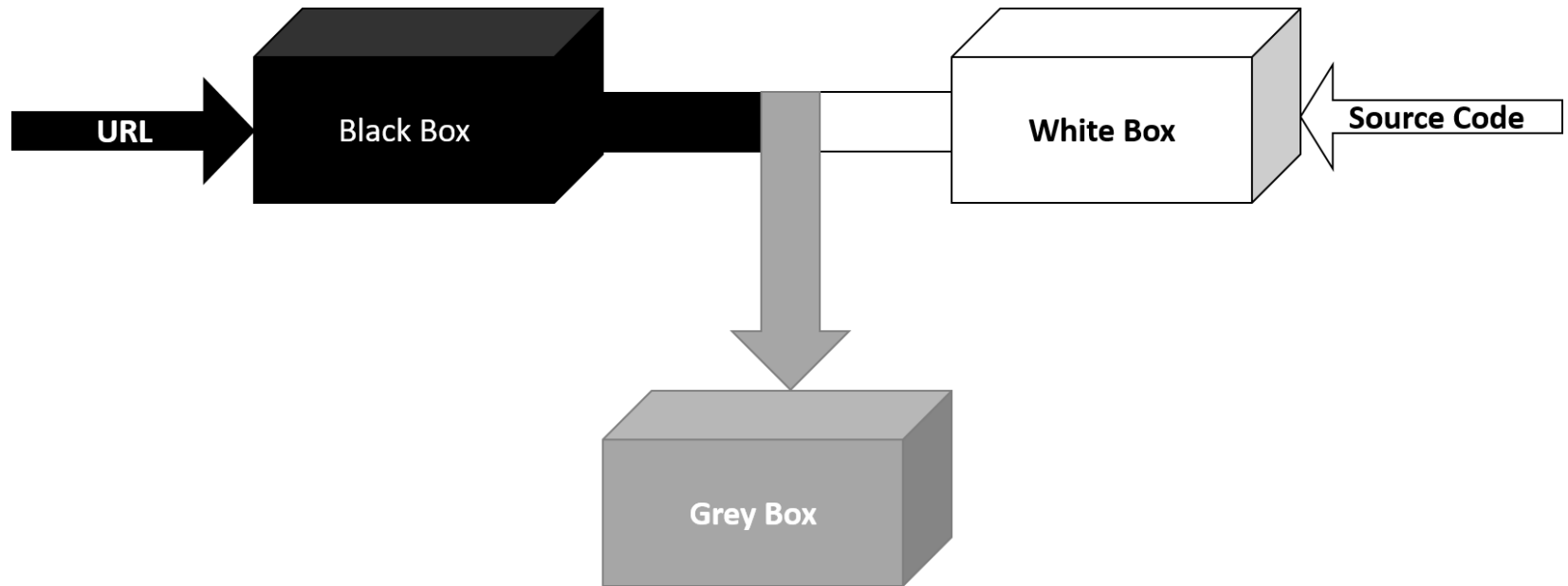
- Little or no information is given about the target
- Only the starting URL provided
- It exploits on the perspective of an external hacker:
 - ✓ Black Hat Hacker
- Is used in an already deployed site

White Box Testing



- Information is given about the target such as:
 - ✓ Source Code
 - ✓ Diagrams
 - ✓ Additional servers
- It exploits on the perspective of an internal hacker:
 - ✓ White Hat Hacker
- Is used during the **development** stage

Grey Box Testing



- Is a combination of black box and white box testing
- It provides greater analyses about the target

Problems Faced by Security Testers

- They Need to demonstrate dangers by exploiting vulnerabilities
- Restrictive times of conducting tests
 - ✓ after hours
- They are restricted in terms of what they can test such as:
 - ✓ Sensitive areas of the application
- Reporting must be in clear and non-technical language
- New threats and vulnerabilities:
 - ✓ Must keep up-to-date with them
- Expected to cover more scope of the application

Summary

Students should now be able to:

- understanding the Internet usage
- Describe the web application security problems
- Identify organizations that are trying to help
- Have an understanding of security testing techniques
- Enumerate challenges facing security testers

Exercise

- List and explain the top 10 web app vulnerabilities

In preparation for Practical

- Read about Kali Linux
- Installation of Kali Linux